SBOM, CVE ve yama kararı

Çıktı · Zafiyet değerlendirmesi · Vulnerability Decision

Azat Öcalır / ABM Makine Sanayi ve Ticaret A.Ş.

SBOM yazılım bileşenlerinin envanteridir. CVE bir zafiyeti tanımlar. CVSS, varsa zafiyetin teknik şiddetini ifade eder. Makineye etkilenme kararı için bileşen, sürüm ve erişim yolu ayrı ayrı doğrulanır.

Alan	Açık bilgi ve ders varsayımı
Gerçek zafiyet	CVE-2023-38545, curl/libcurl SOCKS5 işleme yolunda bellek taşmasıdır. curl duyurusu şiddeti yüksek olarak belirtir.
Sürüm ve düzeltme	7.69.0-8.3.0 aralığı etkilenir. Düzeltme 8.4.0 sürümünde yayımlanmıştır.
Varsayımsal SBOM satırı	OT DMZ tanılama aracı → libcurl 8.2.1. Bileşenin bu modeldeki veya herhangi bir ABM servis yazılımındaki varlığı doğrulanmamıştır.

Üç kanıtla karar

1. Varlık. Envanter veya paket içeriğiyle libcurl doğrulanır. **2. Sürüm.** Etkilenen aralık ve sağlayıcının geriye dönük yama kaydı karşılaştırılır. **3. Erişim.** SOCKS5 uzak ad çözümleme yolunun kullanım ve erişilebilirlik durumu incelenir.

> **Karar · PNK-AC-CNC 1500 için etkilenme doğrulanamadı**
> Varsayımsal araçta üç koşul sağlanırsa servis erişimi sınırlandırılır, ilgili vekil yolu kapatılır ve sağlayıcının desteklediği düzeltilmiş sürüm yalıtılmış ortamda denenir. Emniyet zincirinin durumu bilinmiyorsa çalışmaya devam kararı sahadaki yetkili ekibin değerlendirmesine bağlıdır.

Kanıt durumu	Kayıt kararı
Bileşen veya sürüm belirsiz	Etkilenme belirsiz. Eksik kanıt ve geçici önlem kaydedilir.
Etkilenen sürüm var, yol kapalı	Etkilenmiş bileşen kalır. Erişim kısıtı geçici önlem olarak kayda alınır.

Yama kabulü. Önce mevcut yapılandırma ve geri dönüş planı korunur. Erişim, kayıt, sürüm ve Föy 1'deki duruş ve yeniden başlatma davranışları test edilir. Kabul ölçütü karşılanmazsa güvenli değişiklik planına göre geri dönülür ve uzak servis kapalı tutulur.

Herkese açık kaynaklar ABM · PNK-AC-CNC 1500 ürün sayfası · curl · CVE-2023-38545 güvenlik duyurusu · NIST SP 800-82 Rev. 3 · OT güvenliği